BOM ANALYSIS

USING OPEN-SOURCE TOOLS

SBOM | CBOM | HBOM

Naman Vaishnav
Forenzy Networks — Internship & Training

What Are SBOM, CBOM & HBOM?

SBOM

Software Bill of Materials

Complete inventory of all software components, libraries, versions, licenses, and known CVEs in a product.

Formats: SPDX, CycloneDX, SWID
Mandated by: US EO 14028, EU NIS2

CBOM

Cryptography Bill of Materials

Inventory of all cryptographic assets: algorithms, key sizes, protocols, certificates, and libraries used for crypto operations.

Key risk: Weak/deprecated crypto, quantum vulnerability

HBOM

Hardware Bill of Materials

Structured inventory of physical components: chips, firmware versions, manufacturer details, and supply chain provenance.

Key risk: Counterfeit parts, outdated firmware

Target & Scope

What Was Analyzed and Why

SBOM & CBOM Target

OWASP Juice Shop

bkimminich/juice-shop:latest

Why: Modern Node.js vulnerable-by-design app with 1,136 NPM packages, rich dependency tree, and many documented CVEs — ideal for realistic SBOM analysis.

Key Stats:

- 1,137 packages
- 1,136 NPM packages
- 136 CVEs (11 Critical)
- Source code: GitHub (juice-shop)

HBOM Target

OpenWRT 22.03.5

ath79/generic - Allnet ALL-WAP02860AC

Why: Widely deployed open-source router firmware representing typical IoT/embedded device security posture. Extracted with Binwalk and analyzed with Firmwalker.

Key Stats:

- 3 SquashFS filesystems extracted
- 6 software components mapped
- 1 Critical + 2 High findings
- No root password (default)

Tools Used

Open-Source Security Toolchain

Syft 1.42.1

SBOM generation (CycloneDX + SPDX)

SBOM

Grype 0.109.0

Vulnerability scanning against SBOM

SBOM

ScanCode 32.5.0

License & copyright detection

SBOM

Semgrep 1.152.0

Static analysis / CBOM crypto scan

CBOM

Binwalk 2.4.3

Firmware extraction & entropy analysis

HBOM

Firmwalker

Firmware filesystem security scanner

HBOM

Docker 28.3.2

Container runtime (Juice Shop)

Infra

SBOM Findings — OWASP Juice Shop

Syft + Grype Analysis | 1,137 Packages | 136 CVEs

1,137	11	81	116
Components	Critical CVEs	High CVEs	Fixable

Top 5 Critical CVEs

GHSA-whpj-8f3w-67p5	vm2	3.9.17	**9.8**	3.9.18
GHSA-g644-9gfx-q4q4	vm2	3.9.17	**9.8**	3.9.18
CVE-2025-15467	libssl3	3.0.17	**9.8**	3.0.18
GHSA-jf85-cpcp-j695	lodash	2.4.2	**9.1**	4.17.12
GHSA-xwcq-pm8m-c4vf	crypto-js	3.3.0	**9.1**	4.2.0

CBOM Findings — Cryptography Audit

Semgrep Analysis | 18 Findings Across 3 Rule Sets

CRITICAL: Hardcoded JWT RS256 Private Key

```
juice-shop/lib/insecurity.ts — line 56
export const authorize = (user = {}) => jwt.sign(user, privateKey, { expiresIn: '6h', algorithm: 'RS256' })
```

Impact: Any attacker with source code access can forge valid JWT tokens for any user, including admin — full authentication bypass.

Semgrep Findings Summary

1 Critical:

Hardcoded JWT private key (RS256)

17 High:

Sequelize SQL injection patterns

18 Total

across p/secrets + OWASP + JS rules

Post-Quantum Readiness

RSA / ECDSA in use

Quantum-vulnerable — susceptible to Shor's algorithm

No PQC detected

No CRYSTALS-Kyber/Dilithium/SPHINCS+ usage found

Recommendation

Migrate to FIPS 204 (ML-DSA / Dilithium) for JWT signing

HBOM Findings — OpenWRT Firmware

Binwalk + Firmwalker Analysis | OpenWRT 22.03.5

CRITICAL: No root password defined on device — default SSH access open to all

Source: /etc/profile — "There is no root password defined on this device! Use the passwd command..."

Firmware Components Identified

- BusyBox ~1.35 — 60+ Unix utilities
- Dropbear SSH 2022.83 — Remote shell
- uhttpd 2022-08 — Web admin server
- OpenSSL 1.1.1t (EOL!) — TLS library
- dnsmasq 2.86 — DNS/DHCP
- LuCI 22.03.5 — Web interface

Security Findings

[Critical] H-001

No root password — factory default

[High] H-002

MD5/plaintext password in configs

[High] H-003

OpenSSL 1.1.1t — EOL Sept 2023

[Medium] H-004

Shadow file migration exposure

License Compliance Findings

ScanCode Toolkit 32.5.0 | 574 Files Scanned

PASS: No GPL or AGPL licenses detected in juice-shop/frontend/src/ (574 files, 100 dirs)

License Types Detected

MIT License

Permissive — attribution only

Apache 2.0

Permissive — attribution + patent clause

License Risk Reference

MIT / Apache 2.0 / BSD — Low Risk

Permissive — safe for commercial use

LGPL — Medium Risk

Derivative of library must be LGPL

GPL v2/v3 — High Risk

Viral effect — derivative must be GPL

AGPL — Critical Risk

SaaS use triggers open-source obligation

Overall Risk Rating

Risk Heatmap Across All BOM Domains

SBOM (Juice Shop)	11	81	29	15	CRITICAL
CBOM (Semgrep)	1	17	0	0	HIGH
HBOM (OpenWRT)	1	2	1	0	CRITICAL
TOTAL	13	100	**30**	**15**	CRITICAL

Key Risk Drivers

vm2 RCE	No Root PW	JWT Key Exposed	EOL OpenSSL
3 sandbox escapes in same package	Default open SSH on firmware	Auth bypass via hardcoded secret	No patches since Sept 2023

Remediation Roadmap

Prioritized Action Items — Immediate to 12 Months

Immediate

- Replace vm2 3.9.17 — migrate to Worker Threads/containerization
- Patch libssl3 — update Docker base image
- Rotate hardcoded JWT private key → env var
- Set root password on all OpenWRT devices

30 Days

- Upgrade jsonwebtoken 0.x → 9.0.0
- Replace raw Sequelize string interpolation with parameterized queries
- Upgrade lodash 2.4.2 → 4.17.21

90 Days

- Upgrade crypto-js 3.3.0 → 4.2.0
- Full FOSSA license scan on all node_modules
- Audit /etc/shadow file permissions on firmware

12 Months

- Integrate SBOM into CI/CD pipeline (GitHub Actions — see sbom-scan.yml)
- Post-quantum migration plan: replace RSA with CRYSTALS-Dilithium

Lessons Learned

What This Analysis Revealed

Scale of Hidden Risk

Before this analysis, 1,137 packages and 136 vulnerabilities were invisible. SBOM makes risk quantifiable and actionable — you cannot fix what you cannot see.

Default Credentials Are Real

The OpenWRT finding of no root password is not theoretical. Devices deployed without a configuration step are immediately exploitable — a supply chain gap, not just a config issue.

Dev Code = Prod Risk

The hardcoded JWT key in insecurity.ts is an intentional Juice Shop vulnerability — but it mirrors real-world developer convenience shortcuts that make it into production codebases regularly.

PQC Is Not Future — It's Now

RSA-based JWT signing is standard today but will be broken by quantum computers within the decade. NIST standards are finalized. Migration planning should start immediately.

CI/CD Is the Scalable Fix

Manual BOM analysis doesn't scale. The GitHub Actions pipeline (sbom-scan.yml) automates SBOM generation on every push and fails builds with Critical CVEs — making security continuous.

License Risk Is Underestimated

Most developers don't read license terms of their dependencies. A single GPL transitive dependency in a commercial product can legally force open-sourcing of the entire codebase.

References & Resources

Standards & Specifications

- NTIA SBOM Overview — ntia.gov/sbom
- CISA SBOM Guidance — cisa.gov/sbom
- CycloneDX Specification — cyclonedx.org
- SPDX Official Docs — spdx.dev
- US Executive Order 14028 — whitehouse.gov
- NIST PQC Standards — csrc.nist.gov/pqc
- NIST SP 800-161 — Hardware Supply Chain

Tools & Lab Targets

- Syft & Grype — github.com/anchore
- Semgrep — semgrep.dev
- ScanCode Toolkit — github.com/nexB/scancode-toolkit
- Binwalk — github.com/ReFirmLabs/binwalk
- Firmwalker — github.com/craigz28/firmwalker
- OWASP Juice Shop — github.com/juice-shop
- OpenWRT — openwrt.org